

Cloud Infrastructure Security & Container Protection

Hardened Azure VM, Secure Dockerfile & Container Scanning, and a Secured Azure Function — with sample evidence captures

Scenario organization: Horizon Valley Medical Center (HVMC)

Capstone project: AccessGuard Health — Microsoft Entra ID & Azure IAM Operations

Rubric item: Cloud Infrastructure Security & Container Protection (Cloud Security 1)

Cloud platform: Microsoft Azure (Resource Group `HVMC-CloudSecurity-RG`)

Builds on: the Azure Management Group structure and Azure Policy guardrails, plus the alerting pipeline, from the Cloud Compliance & Governance Controls and Cloud Security Operations & Incident Response submissions

Report date: October 7, 2026

Created by: Sabitha S Karanavar

This submission is prepared as a classroom lab exercise for the HVMC simulation used in this capstone. The terminal and console panels below are sample/illustrative captures showing exactly what a real screenshot should contain — they are stylized mockups, not photographs of a live system, and should be replaced with your own screenshots once the configuration is built in your Azure subscription (see the companion Azure Configuration Checklist).

Rubric Cross-Reference

Rubric Requirement	Where Addressed
Harden one cloud VM: automated patching, host firewall, secure SSH access, with documentation and screenshots	Section 1 — Cloud Virtual Machine Hardening
Create a secure Dockerfile with best practices, configure Docker security settings, and scan with Trivy with documented results	Section 2 — Container Security
Secure one serverless function with proper IAM roles and network isolation	Section 3 — Serverless Function Security

Platform note: this rubric item names AWS-specific services (EC2, Lambda, IAM roles). HVMC's actual lab environment for this capstone is built on **Microsoft Azure**. This document satisfies the same hardening and container-security requirements using Azure's native equivalents — an **Azure VM** in place of EC2, **Azure Update Manager** in place of SSM Patch Manager, and an **Azure Function** secured with **Azure RBAC + a system-assigned managed identity** and **Regional VNet Integration** in place of a Lambda function with an IAM role and VPC endpoints. The Dockerfile, Docker daemon settings, and Trivy scan in Section 2 are infrastructure-agnostic (OS/container-level) and are unchanged by the platform.

1. Cloud Virtual Machine Hardening

Target VM: `HVMC-Util-VM01` — an Ubuntu 22.04 LTS Azure VM in the Production-Workloads Management Group / `HVMC-CloudSecurity-RG` resource group (established in the Cloud Compliance & Governance Controls submission), deployed in `HVMC-App-Subnet` with no public IP, reachable only through `HVMC-Bastion`, and used for the IAM/Identity Administrator's utility and reporting scripts.

1.1 Automated Patching

Patching is managed centrally through **Azure Update Manager** rather than an ad-hoc cron job, so patch compliance rolls up into the same subscription-wide visibility as the Azure Policy compliance scans from the Governance Controls submission.

Azure Portal > Update Manager > Machine: HVMC-Util-VM01

Update schedule	hvmc-patch-window — Sundays 02:00–04:00 ET
Assessment mode	Automatic (periodic assessment enabled)
Patch classification	Critical, Security — install within 0 days of release
Last scan	2026-10-05 02:17 ET
Compliance status	COMPLIANT — 0 Critical/Security updates missing

1.2 Host Firewall

UFW (Uncomplicated Firewall) is enabled with a default-deny inbound policy; only SSH is permitted, and only from the IAM/Identity Administrator's management CIDR via `HVMC-Bastion` — not from `0.0.0.0/0`. This OS-level control is independent of, and layered under, the platform (UFW works identically regardless of cloud provider).

```
admin@HVMC-Util-VM01: ~  
$ sudo ufw status verbose  
Status: active  
Logging: on (low)  
Default: deny (incoming), allow (outgoing), disabled (routed)  
  
To Action From  
--  
22/tcp (SSH mgmt) ALLOW IN 10.0.4.0/26 (AzureBastionSubnet)  
Anywhere DENY IN Anywhere  
Anywhere (v6) DENY IN Anywhere (v6)
```

1.3 Secure SSH Access

- Password authentication disabled — key-based authentication only
- Direct root login disabled
- `fail2ban` enabled, banning an IP for 1 hour after 5 failed attempts in 10 minutes
- Source IP already restricted at the network layer by `HVMC-App-NSG` (no direct SSH from the internet; all administrative access routes through `HVMC-Bastion`), matching the Defender for Cloud recommendation "Management ports should be closed on your virtual machines" from the Cloud Security Operations & Incident Response submission — this host config is a second, independent layer of defense

```
admin@HVMC-Util-VM01: /etc/ssh/sshd_config.d  
$ cat 99-hvmc-hardening.conf  
# HVMC SSH hardening — applied 2026-09-22  
PermitRootLogin no  
PasswordAuthentication no  
PubkeyAuthentication yes  
MaxAuthTries 3  
ClientAliveInterval 300  
ClientAliveCountMax 2  
AllowUsers iam-admin  
  
$ sudo fail2ban-client status sshd  
Status for the jail: sshd  
|- Filter  
| |- Currently failed: 1  
| |- Total failed: 14  
|- Actions  
| |- Currently banned: 1  
| |- Total banned: 6
```

1.4 Documentation Summary

Control	Configuration	Evidence
Automated patching	Azure Update Manager, weekly window, 0-day install for Critical/Security updates	Update Manager compliance panel, §1.1
Host firewall	UFW default-deny inbound, SSH only from the Bastion subnet CIDR	<code>ufw status verbose</code> , §1.2
Secure SSH	Key-only auth, no root login, fail2ban, 3-attempt limit, Bastion-only reachability	<code>sshd_config</code> + fail2ban status, §1.3

2. Container Security

Target application: `hvmc-scheduling-api` — the Scheduling API container from the HVMC Patient Portal (the same application referenced in the Cloud Architecture Design & Security Patterns submission), hosted on `HVMC-Util-VM01` in `HVMC-App-Subnet`.

2.1 Secure Dockerfile

```
# syntax=docker/dockerfile:1
# --- build stage: compile dependencies only, discarded from the final image ---
FROM python:3.12.6-slim-bookworm AS builder
WORKDIR /build
COPY requirements.txt .
RUN pip install --no-cache-dir --user -r requirements.txt

# --- final stage: minimal runtime, no build tools, non-root user ---
FROM python:3.12.6-slim-bookworm
LABEL maintainer="HVMC IAM Operations"
RUN addgroup --system app && adduser --system --ingroup app --no-create-home appuser
WORKDIR /app
COPY --from=builder /root/.local /home/appuser/.local
COPY --chown=appuser:app . .
ENV PATH=/home/appuser/.local/bin:$PATH \
    PYTHONDONTWRITEBYTECODE=1 \
    PYTHONUNBUFFERED=1
USER appuser
EXPOSE 8080
HEALTHCHECK --interval=30s --timeout=3s --retries=3 \
    CMD python -c "import urllib.request;urllib.request.urlopen('http://localhost:8080/health')" ||
    exit 1
ENTRYPOINT ["python", "app.py"]
```

Best practices applied: pinned, minimal base image (no `latest` tag); multi-stage build so compilers/build tools never reach the final image; dedicated non-root `appuser`; no secrets or credentials baked into the image (configuration is injected at runtime from **Azure Key Vault** via a managed identity); an explicit `HEALTHCHECK`; and a `.dockerignore` excluding `.env`, `.git`, and test fixtures from the build context.

2.2 Docker Security Settings

```
# /etc/docker/daemon.json – host-level hardening
{
  "icc": false,
  "userland-proxy": false,
  "live-restore": true,
  "userns-remap": "default",
  "log-driver": "json-file",
  "log-opts": { "max-size": "10m", "max-file": "3" }
}

# Runtime flags used to launch the container
```

```
docker run -d --name hvmc-scheduling-api \
  --read-only --tmpfs /tmp \
  --cap-drop=ALL \
  --security-opt=no-new-privileges:true \
  --pids-limit=100 --memory=256m --cpus=0.5 \
  --network hvmc-app-net \
  hvmc-scheduling-api:1.4.0
```

What each setting buys: inter-container communication disabled (`icc:false`) so only explicitly-linked services can talk to each other; `--read-only` plus a `--cap-drop=ALL` stops a compromised process from writing to the filesystem or escalating privileges; the resource limits cap the blast radius of a runaway or malicious process.

2.3 Container Scanning with Trivy

```
admin@HVMC-Util-VM01: ~
$ trivy image --severity CRITICAL,HIGH,MEDIUM,LOW hvmc-scheduling-api:1.4.0

hvmc-scheduling-api:1.4.0 (debian 12.6)
=====
Total: 7 (CRITICAL: 0, HIGH: 0, MEDIUM: 2, LOW: 5)
```

Library	Vulnerability	Severity	Fixed Version
libexpat1	CVE-2024-8176	MEDIUM	2.6.3-1
zlib1g	CVE-2023-45853	MEDIUM	1:1.3.dfsg-3.1
libc-bin	CVE-2024-33601	LOW	(monitor upstream)

Scan	Base Image	Result
Before remediation (2026-09-20)	python:3.9 (unpinned)	CRITICAL: 2 HIGH: 9 MEDIUM: 14 LOW: 21
After remediation (2026-09-23)	python:3.12.6-slim-bookworm (pinned)	CRITICAL: 0 HIGH: 0 MEDIUM: 2 LOW: 5

Remediation was a base-image swap (unpinned `python:3.9` → pinned, minimal `python:3.12.6-slim-bookworm`) plus the multi-stage build in §2.1, which together eliminated every Critical and High finding; the two remaining Medium findings have no upstream fix yet and are tracked for re-scanning on the next base-image update.

3. Serverless Function Security

Target function: `hvmc-alert-router` — an Azure Function that receives the Azure Monitor security alerts built in the Cloud Security Operations & Incident Response submission and formats them before they reach the appropriate Action Group, so the alerting pipeline includes one deliberately-secured serverless component rather than only managed Azure services.

3.1 Azure RBAC Role — Least Privilege (System-Assigned Managed Identity)

```
{
  "Name": "HVMC Alert Router - Least Privilege",
  "IsCustom": true,
  "Description": "Notify named Action Groups and write only to this function's own Application Insights resource.",
  "Actions": [
    "Microsoft.Insights/actionGroups/createNotifications/action",
    "Microsoft.Insights/components/hvmc-alert-router-insights/write"
  ],
  "NotActions": [],
  "AssignableScopes": [
    "/subscriptions/<sub-id>/resourceGroups/HVMC-CloudSecurity-RG/providers/Microsoft.Insights/actionGroups/security-critical",
    "/subscriptions/<sub-id>/resourceGroups/HVMC-CloudSecurity-RG/providers/Microsoft.Insights/actionGroups/security-high",
    "/subscriptions/<sub-id>/resourceGroups/HVMC-CloudSecurity-RG/providers/Microsoft.Insights/actionGroups/security-medium",
    "/subscriptions/<sub-id>/resourceGroups/HVMC-CloudSecurity-RG/providers/Microsoft.Insights/components/hvmc-alert-router-insights"
  ]
}
```

No wildcard scopes on the notification or logging actions — the function's system-assigned managed identity can trigger only the three named Action Groups and write only to its own Application Insights resource, not the subscription's broader monitoring infrastructure. (Regional VNet Integration, used in §3.2 for network isolation, is a Function App networking setting rather than an RBAC-granted permission, so it is not listed as a role action here.)

3.2 Network Isolation

Function App > `hvmc-alert-router` > Networking

VNet	HVMC-Prod-VNet
Subnet	HVMC-App-Subnet (Regional VNet Integration, route-all enabled)
Route table	no default route to a NAT Gateway or Internet; private-only egress
Outbound path	Private Endpoints via Azure Monitor Private Link Scope (AMPLS) for Action Groups and Application Insights — no public internet route

Running the function with Regional VNet Integration into a private subnet with no internet route — reaching Action Groups and Application Insights only through Private Endpoints behind an Azure Monitor Private Link Scope — means a compromised function has no path to exfiltrate data to the public internet, consistent with the same "deny public egress unless explicitly required" posture used for the Azure VM in Section 1.

3.3 Test Invocation



```
admin@HVMC-Util-VM01: ~  
  
$ curl -X POST "https://hvmc-alert-router.azurewebsites.net/api/routealert?code=***" \  
-H "Content-Type: application/json" \  
-d '{"source":"defender-for-cloud","severity":8.5}'  
  
{  
  "routed_to": "security-critical",  
  "status": "published"  
}
```

Sources: *HVMC_Cloud_Compliance_and_Governance_Controls.pdf*, *HVMC_Cloud_SecOps_and_Incident_Response.pdf*, *HVMC_Azure_Configuration_Checklist.pdf* (companion submissions). Terminal and console panels are sample/illustrative captures — replace with your own screenshots once built in your Azure subscription. Prepared as the Cloud Infrastructure Security & Container Protection deliverable for the Semester 4 Healthcare IAM Operations Home Lab capstone.